

Evaluation guidelines [IOS3100, IoT/OT security] [Resit 2026]

Learning outcomes

Knowledge. The student...

- 1 can define and explain security issues in IoT systems
- 2 can explain and problematize how the spread of IoT systems in both our daily lives and critical infrastructure will affect security from a societal perspective
- 3 can define and explain selected architectures and protocols in use in IoT devices
- 4 can define and explain security issues in OT systems
- 5 can explain patch problems related to running OT systems, understand what risks may be associated with this from an operational perspective and from a security perspective
- 6 can define and explain selected architectures in use in OT environments
- 7 can explain the challenges and benefits of performing penetration tests in an OT environment

Skills. The student...

- 1 can use tools for static security analysis and code auditing
- 2 can understand the principles behind reverse engineering of hardware and software in an embedded / IoT device, and what effects this has on security
- 3 can carry out a vulnerability analysis / penetration test of IoT devices
- 4 can use tools to carry out vulnerability analyzes and risk analyzes of an OT environment / system
- 5 can analyze protocols used in IoT systems, and use this to uncover security vulnerabilities

General competence. The student...

- 1 can understand and problematize the advantages and disadvantages associated with the emergence of IoT devices and OT systems that are connected to the Internet
- 2 can carry out a security analysis of an IoT product, and understand what threats this product can introduce if it is used in the contexts; private, company and public
- 3 can carry out safety management and risk management of OT projects

Grading Criteria

- use of terms from IoT security
- comprehensive and relevant examples from materials of the course
- understanding how microcomputers and microcontrollers work and what are the mechanisms used to secure those
- the student needs to answer tasks **A + B + C** to achieve 100% of the grade.

Applicable forms of assessment and instructional methods

- theoretical lectures and practical exercises from the course

Grading Scale

Point total and grading scale

Letter Grade	Corresponding numerical grade
A	90-100
B	80 – 89
C	60 - 79
D	50 - 59
E	40 - 49
F	0 - 39

Part 2 – Reviewing the assignment

Assignment 1 (100%)

Task A – theoretical task (20% of the grade)

A. 1: Reflect on the learning from the two guest lectures we had in this course based on their content and the essential aspects of IoT security that each guest lecturer highlighted. Present how this knowledge helped you to better understand concepts from the course. **(10%)**

A. 2: Based on the guest lecture presentation titled “Selected Aspects of Smart Manufacturing Infrastructure Security and Resilience”, particularly slide 12 on “Cybersecurity Landscape in Manufacturing – Threats SM”, discuss one cybersecurity threat (e.g., ransomware; industrial espionage; supply chain attacks). Your explanation should include: (1) a brief description of each threat, (2) why it is critical in the context of interconnected manufacturing systems, and (3) a short example or scenario illustrating its impact. **(10%)**

[What gives point]

(10 points) Task A.1: The student needs to present a discussion and analysis of two selected guest lecturers who gave talks during the course.

(10 points) Task A.2. Students should clearly describe one manufacturing-related cybersecurity threat, explain why it matters in connected industrial systems, and give a simple, relevant example showing its possible impact.

Task B – Security Analysis of IoT-Based Health Monitoring System (40%)

You are required to perform a structured threat and risk analysis of a typical IoT-based health monitoring system (e.g., wearable/body sensor network connected to a mobile app and cloud backend) using the STRIDE and DREAD models, following the steps below.

B.1: STRIDE-Based Threat Modeling (20%)

1. Define the Architecture

Describe the key components of an IoT-based health monitoring system, for example:

- Physiological sensors (Heart Rate, Respiratory Rate, Blood Pressure, SpO₂)
- Wearable device / sensor node
- Microcontroller / embedded processor
- Wireless communication module (Bluetooth Low Energy / Wi-Fi)
- Mobile gateway (smartphone / tablet)
- Cloud server / backend
- Healthcare dashboard / clinician interface
- Power source (battery)

Provide a block diagram showing the main modules and their connections (sensor → wearable → gateway → cloud → user).

2. Decompose into Components

Break the system into 5–8 logical components. For each component, briefly describe:

- Its primary function
- Its interfaces (data inputs/outputs, communication links)

3. Identify STRIDE Threats

For each component, identify one relevant threat using the STRIDE model:

- Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, and Elevation of Privilege

For each threat, explain:

- How the attack could happen
- Its impact on patient safety, data privacy, or system reliability

4. Draw Trust Boundaries

Create a trust boundary diagram showing where data or control crosses boundaries, for example:

- Sensor → Wearable device
- Wearable → Mobile gateway
- Mobile gateway → Cloud server
- Cloud → Healthcare professional dashboard

Clearly indicate trusted and untrusted zones.

B.2: DREAD-Based Risk Analysis (20%)

1. Describe the Attack Scenarios

Select two realistic attack scenarios based on your B.1 threats.

2. Apply the DREAD Model

For each attack scenario, score the following on a scale of 0–10:

- Damage Potential
- Reproducibility
- Exploitability
- Affected Users
- Discoverability

Compute and report the average risk score. Briefly explain the severity and overall risk level (low / medium / high) and discuss the potential impact on patient safety and privacy. In the report, the following should be included in Figures/Flowchart/Table format

- Clear headings for B.1 and B.2
- Diagram(s) for architecture and trust boundaries
- Tables for DREAD scoring

[What gives point]

(20 points) Task B.1: The student must perform a STRIDE-based threat modeling of an IoT-based health monitoring system by describing the system architecture, presenting a clear block diagram, decomposing the system into logical components, identifying one relevant STRIDE threat per component, and explaining the potential impact on patient safety, data privacy, or system reliability. Trust boundaries between system components must be clearly identified using appropriate IoT security terminology.

(20 points) Task B.2: The student must conduct a DREAD-based risk analysis by selecting two realistic attack scenarios, scoring each scenario using the DREAD criteria, calculating the average risk score, and classifying the overall risk level as low, medium, or high, with a brief explanation of the impact on patient safety and privacy.

Task C – Practical Task (40% of the grade)

C.1: Design and implement a simple MQTT-based IoT application that will include three components:

- a plant/flowers watering and monitoring station
- a server-based cloud solution that aggregates all information
- a user-based mobile client that demonstrates historical conditions of the soil humidity.

This can be an emulated IoT ecosystem (without physical sensors) using virtual machine(s) OR at docker instance(s). Draw a diagram of the designed system. The system should include at least a database, IoT application protocols, a central broker, and a client application. You can use either of the technologies: Mosquitto, MQTT Explorer, MySQL, OpenStack, Python, PHP or similar with default configurations. Demonstrate vulnerabilities and possible weaknesses of the system, and perform any types of attacks that you have learnt in the program reflecting the OWASP Top 10 IoT Security Risks (https://wiki.owasp.org/index.php/OWASP_Internet_of_Things_Project). Suggest possible protection and security measures. (30%)

C.2: In this course, you have learned about the importance of security assessment in IoT applications. Pick any open-source projects implemented for any Arduino / ESP32 boards (from <https://github.com/>, <https://projecthub.arduino.cc/>, etc). The project must include any type of web server implementation that is accessible through the network. Download the main .ino file from a project and present a simple diagram of functionality implemented in setup() and loop() procedures. Analyze the selected IoT project and write a list of corresponding Devices Properties, Threats and Mitigations according to MITRE EMB3D™ Threat Model framework (<https://emb3d.mitre.org/>). All three categories need to include corresponding identifiers and descriptions from EMB3D for each of the assessment steps (<https://emb3d.mitre.org/getting-started/>). (10%)

[What gives point]

(30 points) Task C.1: The student must present all possible technologies learned in the IoT security course and from before and draw a diagram of the suggested plant watering system. This can include the installation of various programs and the implementation of scripts. The student needs to demonstrate a thorough understanding of IoT ecosystems, what types of attacks exist and how to mitigate them in light of OWASP Top 10 framework.

(10 points) Task C.2: The student must demonstrate an understanding of how threat assessment works using community-accepted frameworks, such as EMB3D. The answer should include both identifiers and a description of the device properties (e.g., PID-11 – Device includes a microprocessor), (e.g., TID-101 - Power Consumption Analysis Side Channel) and Mitigations (MID-001: Software Only Bootloader Authentication).